3. Assessment Methodology

3.1 Methodology Overview

The IT Security Risk Assessment followed a structured approach combining automated vulnerability identification, technical evidence review, risk analysis, internal control mapping, and risk treatment planning.

Greenbone Community Edition was used to assess an intentionally vulnerable Metasploitable Linux virtual machine hosted within a Proxmox laboratory environment.

The methodology was designed to demonstrate how vulnerability assessment results can support IT security risk management and governance activities.

The assessment consisted of six phases:

Phase	Assessment Activity	Purpose
1	Assessment Preparation	Establish the assessment environment and target
2	Vulnerability Scanning	Identify technical vulnerabilities using Greenbone
3	Finding Validation and Analysis	Review detection evidence and consolidate related findings
4	Risk Assessment	Evaluate potential likelihood and business impact
5	Internal Control Mapping	Identify relevant COSO and NIST SP 800-53 control considerations
6	Risk Treatment and Reporting	Document recommendations, priorities, and management reporting

The assessment was performed in a controlled laboratory setting. The resulting business risk ratings and management assignments were developed for a simulated production scenario.

3.2 Phase 1 — Assessment Preparation

The assessment environment was established using Proxmox VE 9.0.3.

Two virtual machines were configured:

- **Greenbone Scanner — VM 121:** Ubuntu 24.04 system hosting Greenbone Community Edition through containerized services.
- **Metasploitable — VM 120:** Intentionally vulnerable Linux system selected as the assessment target.

The Greenbone scanner used IP address `10.10.50.20` on the laboratory network, while Metasploitable used `10.10.50.10`.

Both systems were connected to the Proxmox laboratory bridge, `vmbr3`, which had no physical network uplink.

The scanner also had a separate management interface at `192.168.1.154`.

To reduce the risk of unintended connectivity between the laboratory and management networks, IP forwarding was disabled and firewall forwarding restrictions were configured.

The target system did not have a default gateway.

These safeguards supported the intended network separation. However, the assessment did not establish complete isolation through an exhaustive review of all potential forwarding paths.

Before scanning, connectivity between the scanner and target was verified.

3.3 Phase 2 — Vulnerability Identification

Greenbone Community Edition was used to perform an automated vulnerability assessment of the Metasploitable target.

The assessment targeted:

IP Address: `10.10.50.10`
Target System: Metasploitable VM 120
Assessment Date: November 3, 2026

The Greenbone vulnerability feeds were updated before the assessment.

The completed scan generated findings across four technical severity categories.

Severity	Number of Results
Critical	13
High	8
Medium	39
Low	6
Total	**66**

The scan report was exported and retained as supporting assessment evidence.

For detailed risk analysis, the assessment prioritized the 13 Critical findings.

The remaining eight High, 39 Medium, and six Low findings were included in the assessment summary but were not individually analyzed in the risk register.

Vulnerability Severity

Greenbone reported technical severity using Common Vulnerability Scoring System (CVSS) scores.

CVSS provides a standardized method for communicating the technical severity of vulnerabilities.

However, CVSS does not independently determine the business risk associated with a vulnerability.

Business risk also depends on factors such as asset criticality, network exposure, potential operational consequences, and the effectiveness of existing security controls.

Consequently, scanner severity and business risk were documented separately.

3.4 Phase 3 — Finding Review and Evidence Analysis

The 13 Critical scan results were reviewed to identify the affected services, reported vulnerabilities, supporting technical evidence, and potential security consequences.

The review considered the following information:

Evidence Element	Purpose
Vulnerability Name	Identifies the reported security weakness
Affected Service and Port	Establishes where the vulnerability was detected
CVSS Score	Indicates technical vulnerability severity
Quality of Detection (QoD)	Indicates Greenbone's reported confidence in the detection
Detection Details	Describes how Greenbone identified the vulnerability
Technical Test Results	Identifies observable responses or demonstrated behavior
Vulnerability Test Identifier	Supports traceability to the underlying Greenbone detection

Evidence Evaluation

Findings were evaluated according to the strength of the available evidence.

The review distinguished between:

Demonstrated security weaknesses: Findings supported by successful authentication, command execution, or unauthorized file access.

Detection-based findings: Findings identified through software version information, service exposure, or Greenbone vulnerability detection logic without independently demonstrated exploitation.

Examples of demonstrated behavior included:

- **Ingreslock backdoor:** Greenbone executed the `id` command and received a response identifying the Linux root account.
- **DistCC:** Greenbone executed the `id` command and received a response identifying the daemon account.
- **MySQL:** Greenbone successfully authenticated as the database root user with an empty password.
- **PostgreSQL:** Greenbone successfully authenticated using the default `postgres` credentials.
- **Apache Tomcat AJP:** Greenbone retrieved the `/WEB-INF/web.xml` file through the AJP connector.

Other findings, including the unsupported Ubuntu operating system and outdated TWiki application, were supported by detection information rather than independently demonstrated exploitation.

The assessment did not assume that every vulnerability resulted in successful system compromise.

Finding Consolidation

The scan identified two Critical results associated with the same vsftpd backdoor vulnerability, reported at TCP ports 21 and 6200.

Because both results concerned the same underlying security weakness, they were consolidated into one risk entry.

This process reduced the 13 Critical scan results to **12 distinct risks**.

Consolidation was performed to avoid double-counting the same underlying risk while preserving the relevant technical evidence.

3.5 Phase 4 — IT Security Risk Assessment

The 12 distinct risks were documented in the IT Security Risk Register.

Each entry included the vulnerability description, affected asset, technical evidence, potential business impact, relevant controls, treatment recommendation, simulated owner, and remediation status.

Business Risk Scenario

Because the assessment was conducted against an intentionally vulnerable laboratory system, a hypothetical production scenario was used to demonstrate enterprise risk assessment practices.

Under this scenario, the affected server was assumed to support business applications and be accessible from an internal corporate network.

Potential consequences were evaluated in terms of unauthorized access, confidentiality, integrity, availability, and operational disruption.

These assumptions were used exclusively for educational and portfolio purposes.

Likelihood and Impact Assessment

A five-point scoring methodology was applied.

Likelihood represented the estimated probability of a threat exploiting the identified weakness under the simulated conditions.

Impact represented the potential severity of the resulting business consequences.

The inherent risk score was calculated using the following formula:

Inherent Risk Score = Likelihood × Impact

The scoring ranges were:

Inherent Risk Score	Risk Rating
1–4	Low
5–9	Medium
10–16	High
17–25	Critical

The assessment produced the following provisional inherent risk distribution:

Risk Rating	Number of Risks
Critical	9
High	3
Medium	0
Low	0
Total	**12**

These ratings were based on the simulated production scenario and were not approved by an actual organization's management.

Inherent and Residual Risk

The assessment focused on **inherent risk**, representing potential risk before considering the effectiveness of applicable mitigating controls.

Residual risk was not calculated because remediation activities and organizational control effectiveness were not assessed.

All 12 registered risks remained open at the conclusion of the assessment.

3.6 Phase 5 — Internal Control Mapping

The documented risks were mapped to relevant internal control concepts using the COSO Internal Control Framework and NIST SP 800-53.

COSO Internal Control Framework

The COSO framework was used to provide a governance and internal control perspective.

The identified technical risks were primarily associated with the **Control Activities** component because they involved safeguards such as:

- Authentication and access restrictions
- Secure system configurations
- Vulnerability remediation
- Software lifecycle management
- Network access controls

The assessment also recognized the importance of the remaining COSO components:

Control Environment: Establishes accountability and expectations for security.

Risk Assessment: Supports identification and evaluation of cybersecurity risks.

Information and Communication: Enables reporting of risks to appropriate stakeholders.

Monitoring Activities: Supports ongoing vulnerability management and remediation verification.

The COSO mappings represented proposed control considerations, not conclusions from formal internal control testing.

NIST SP 800-53

NIST SP 800-53 was used to identify security controls relevant to the registered vulnerabilities.

The mappings included controls associated with:

Control Area	Example NIST Controls
Access Control	AC-3, AC-6, AC-17
Identification and Authentication	IA-5
Configuration Management	CM-6, CM-7, CM-8
System and Information Integrity	SI-2
System and Communications Protection	SC-7, SC-8

These mappings provided a basis for recommending security improvements.

However, the assessment did not evaluate whether an organization had formally implemented these controls or whether they operated effectively.

3.7 Phase 6 — Risk Treatment Planning and Reporting

A Risk Treatment Plan was developed for the 12 documented risks.

The plan identified:

- Recommended remediation actions
- Treatment strategies
- Simulated risk owners
- Remediation priorities
- Proposed validation methods
- Remediation status
- Residual risk assessment status

All 12 risks were assigned a proposed **Mitigate** treatment strategy.

Based on the provisional inherent risk ratings:

Treatment Priority	Number of Risks
P1 — Critical	9
P2 — High	3
Total	**12**

Recommended treatment activities included removing backdoors, disabling insecure services, strengthening authentication, upgrading unsupported technology, and restricting unnecessary network exposure.

Validation methods were documented to describe how remediation could be verified if corrective actions were implemented.

No remediation actions were performed during the assessment.

Therefore, all risks remained open, remediation was not started, and residual risk remained unassessed.

Management Reporting

The assessment results were organized into four supporting worksheets:

1. **Risk Register:** Documents the 12 risks, supporting evidence, provisional scores, and proposed controls.
2. **Risk Scoring Methodology:** Defines the likelihood, impact, and risk rating criteria.
3. **Risk Treatment Plan:** Records recommended actions, priorities, ownership, and validation methods.
4. **Executive Dashboard:** Summarizes the technical findings and simulated business-risk distribution.

These worksheets support the formal IT Security Risk Assessment Report and provide traceability between technical findings and management recommendations.

3.8 Methodology Limitations

The assessment methodology had several limitations.

First, the technical findings originated from an automated vulnerability scan. Although some findings included demonstrated security weaknesses, not every reported vulnerability was independently exploited or manually validated.

Second, detailed analysis was limited to the 13 Critical scan results. The remaining findings were not individually assessed.

Third, the business risk ratings were based on hypothetical production assumptions rather than an actual organization's operating environment, business processes, and risk appetite.

Fourth, the assessment did not include formal organizational control testing, remediation implementation, management approval, or residual risk validation.

These limitations were considered when interpreting the results and developing the assessment conclusions.

3.9 Methodology Conclusion

The assessment methodology established a repeatable process for translating technical vulnerability findings into documented IT security risks.

By combining automated scanning, evidence review, finding consolidation, likelihood and impact analysis, internal control mapping, and treatment planning, the project demonstrated how cybersecurity assessment results can support IT governance and risk management activities.

The resulting documentation provides a foundation for management reporting and future remediation tracking while maintaining a clear distinction between verified technical evidence and simulated business-risk assumptions.